AIPoPh Internal Audit 2 - Happy Path Audit

The aim of this second internal audit is to conduct thorough end-to-end system test on AIPoPh, ensuring the happy path functions as intended. The audit will result in a detailed report outlining our findings, proposed strategies for addressing any issues uncovered, and potential mitigations.

Findings

The findings of our second internal audit is below in no particular order.

IA-1: ***Standardize shebang across all happy path scripts***

Severity: Low Risk

Status: Completed https://github.com/projectNEWM/newm-aipoph/pull/40

Files Affected: All Scripts

Description: `#!/usr/bin/env bash` is considered more standard and portable because it allows the script to work across a wider range of Unix-like systems without modification.

Recommendation: Change all `#!/bin/bash` into `#!/usr/bin/env bash`.

IA-2: ***Remove all notion of the drep system***

Severity: Low Risk

Status: Completed https://github.com/projectNEWM/newm-aipoph/pull/41

Files Affected: 01_genesisMint.sh

Description: The drep system has been removed. All notion of it inside the happy path should be removed.

Recommendation: Remove anything related to the drep system.

IA-3: ***Update DAO to reference inside the happy path***

Severity: Low Risk

Status: Completed https://github.com/projectNEWM/newm-aipoph/pull/42

Files Affected: All Scripts

Description: The dao contract has been updated into the reference contract to reflect its purpose better. The old naming convention still exists inside the happy path.

Recommendation: Update dao into reference where applicable.

IA-4: ***Update happy path readme with helpful information***

Severity: Informational

Status: Completed https://github.com/projectNEWM/newm-aipoph/pull/43

Files Affected: README.md

Description: The happy path readme needs to have information about setting up the `.env` file, setting up the wallets, and some general token information.

Recommendation: A quick write is all that is needed here.

IA-5: ***Set up .env for preview***

Severity: Low Risk

Status: Completed https://github.com/projectNEWM/newm-aipoph/pull/44

Files Affected: .env.preview

Description: All networks should be supported.

Recommendation: Create a `.env.preview` file for the preview network.

IA-6: ***Update start_info.json into config.json***

Severity: Low Risk

Status: Completed https://github.com/projectNEWM/newm-aipoph/pull/45

Files Affected: All Scripts

Description: The old naming convention was `start_info.json`. This file is now `config.json`.

Recommendation: Update all occurrances of `start_info.json` into `config.json`.

IA-7: ***Add genesis pointer token prefix to config.json***

Severity: Low Risk

Status: Completed https://github.com/projectNEWM/newm-aipoph/pull/46

Files Affected: All Scripts

Description: The value is hardcoded to the happy path scripts. If it were to change then every file would need an update. Put the pointer prefix into the `config.json` file and update all the hardcoded strings into a jq function.

Recommendation: Change

```
pointer_prefix="5f6169706f70685f"
```

into

```
pointer_prefix=$(jq -r '.pointer_prefix' ../../config.json)
```

IA-8: ***Update Vault add and sub redeemers to new data structure***

Severity: Low Risk

Status: Completed https://github.com/projectNEWM/newm-aipoph/pull/47

Files Affected: add-redeemer.json, sub-redeemer.json

Description: The vault redeemer structure changed from the Token type into the Tokens type. The example value of 1 ADA can be kept the same but the redeemers need to be updated to use the Tokens type.

Recommendation: The Tokens type is a list of Token types. Update the data structure to the new type.

IA-9: ***Remove erroneous data copies, echo statements, and correct all wallet comments***

Severity: Low Risk

Status: Completed https://github.com/projectNEWM/newm-aipoph/pull/48

Files Affected: All Scripts

Description: Some of the scripts have extra data copy occurring at the bottom of the script, others have echo statements that are printing incorrect information to the console, and some of the wallets are misidentitfied with the comments above them.

Recommendation: Remove the useless data copies, review all the echo statements, and fix the comments to make sure they make sense for what they are trying to describe.

IA-10: ***The user-wallet should pay for the transactions, the voter-wallet should just be spending their utxos back to themselves.***

Severity: Low Risk

Status: Acknowledged The user pays for things the user does and when applicable the voter just sends their value back to themselves.

Files Affected: All Scripts

Description: The voter wallet just provides the access to the action token while the user wallet should be the one paying for the transaction fees.

Recommendation: Add in an extra explicit tx out to the transactions that accounts for the voter wallet sending their funds back to themselves and make sure the user wallet is paying for the transactions. This can be applied to all or most of the happy path scripts that require both the voter and the user to interact.

IA-11: ***Current lovelace amounts should not be hardcoded and should be based off of current utxo state***

Severity: Low Risk

Status: Acknowledged All lovelace amounts should be based off of the utxo state. The only amounts are the assumed happy path values like the default 1 ada test for vault or the 2 ada for fees.

Files Affected: All Scripts

Description: Some happy path scripts get the current lovelace value from the utxo set while others are hardcoding the value. Standardize this by making each script use the utxo set to get the current lovelace value.

Recommendation: Instead of doing something like this:

```
current_lovelace=$((${min_utxo} + 3000000 + 2000000))
```

do something like this when applicable:

```
lovelace_value=$(jq -r '.[].value.lovelace' ../tmp/script_utxo.json)
```

IA-12: ***Update TxSimulation to the most recent version***

Severity: Low Risk

Status: Acknowledged TxSimulation relies on Koios. Koios updated their API from v0 to v1. A simple version change fixed this.

Files Affected: 02_startPoHTest.sh, 05_verifyPoHTest.sh

Description: Koios updated their api from v0 to v1 resulting in this version of TxSimulation to stop working properly.

Recommendation: Update to the newest version of TxSimulation.

IA-13: ***Remove erroneous contracts when not in use inside a happy path script***

Severity: Low Risk

Status: Acknowledged; Solved in IA-09

Files Affected: All Scripts

Description: Some contracts are inside of scripts but are never used. There are cases where the utxos for that contract are being queried and never used either. This information is not required for functionality.

Recommendation: Review each happy path script and make sure each contract defined at the top level is actually being used inside the transaction. If it is not being used then remove it.

IA-14: ***Add the PoH and CoH token name into the config.json file***

Severity: Low Risk

Status: Acknowledged; Solved in IA-07

Files Affected: All Scripts

Description: The token names should not be hardcoded inside of happy path scripts. If they were to change then many files would have to be updated which could causes issues.

Recommendation: Add the token names to the `config.json` file then use a jq statement to query the value.

IA-15: ***Add in CoH happy path scripts***

Severity: High Risk

Status: Completed https://github.com/projectNEWM/newm-aipoph/pull/49

Files Affected: coh related

Description: The coh folder needs the ability to verify the coh and needs to be able to revoke the coh.

Recommendation: Create these files as they are the last step on the e2e test.

IA-16: ***Review required python scripts and add documentation***

Severity: Informational

Status: Completed https://github.com/projectNEWM/newm-aipoph/pull/50

Files Affected: py/

Description: Most of the required python scripts are well documented but some are not.

Recommendation: As the testing progress, review each file and make sure it has comments describing each funciton.

IA-17: ***A complete end-to-end test with links to transactions***

Severity: Informational

Status: Completed https://github.com/projectNEWM/newm-aipoph/pull/51

e2e transaction proof

Files Affected: All Scripts

Description: Do a complete end to end test on AIPoPh. Start with a brand new genesis and end with the revoking of a certificate of humanity. At each step note the transaction id for reference later.

Recommendation: Link each transaction at each step below.

Conclusion

There was a single High Risk, 13 Low Risk, and 3 Informational findings. 5 findings are acknowledged as some are duplicates and others are not required.

Overall the scripts have been massively improved upon and some subtle issue with the validation logic have been updated. Noteably, the signed data verification now requires the public key from the cardano s key to be provided then verified in the off-chain during the test taking part of the protocol. Blake2b-224 is not available on-chain so this verificiaton must be off-chain. Some CoH validation logic was rearranged due to preventing revoke from working properly. It was a minor change of the order of the logic and not he logic itself.

The TxSimulation code has been optimized. Now the correct script ordering is used dynamically when starting, verifying, and revoking.